Checklist Oficial de Entrega Projeto Final

Projeto Final DevSecOps Clube Aurora (Turma 1746)

> Antes de submeter o seu projeto final, revise este checklist com atenção.
> Cada nível possui requisitos específicos de entrega. Escolha a seção correspondente ao seu nível e marque todos os itens para garantir a nota máxima!

Regras Gerais (Válidas para Todos os Níveis)

- [ ] O arquivo de entrega está no formato Markdown (`.md`) ou PDF/Word devidamente exportado sem formatação quebrada.
- [ ] Seu nome completo e turma (**DevSecOps 1746**) estão preenchidos no cabeçalho do relatório.
- [ ] **Transição de Trilhas:** Caso tenha iniciado em uma trilha e decidido migrar (upgrade ou fallback seguro), verifique se o template submetido corresponde à trilha final escolhida (consulte `ENUNCIADO.md`).
- [ ] **Validação Local:** Para Níveis 2 e 3, utilizou os comandos de inspeção e autochecagem do `PLANO_DE_TESTES_DEBUGGING.md` antes de enviar os commits.
- [ ] Todas as respostas são de sua autoria original ou com citações claras e justificadas.
- [ ] A entrega foi realizada dentro das orientações e antes do prazo limite estipulado pela **professora**.

[SEGURANÇA] Nível 1 Teórica Guiada

Você **não** precisa alterar código-fonte nem abrir Pull Requests no GitHub. Sua entrega é exclusivamente o relatório preenchido com base nas evidências pré-geradas.

Arquivos e Conteúdo:

- [ ] O relatório `aluno/TEMPLATE_TG.md` (ou via Word em `docs/docx/TEMPLATE_TG.docx`) foi preenchido por completo.
- [ ] **Guia de Apoio:** Consultou o `GUIA_NIVEL_1_TEORICO.md` para apoiar seu raciocínio com analogias e sem vazamento de respostas.
- [ ] **Caso 1 (F1):** O exemplo resolvido serviu de base para as suas respostas.
- [ ] **Caso 2 (F2 - Dependências SCA):** Lacunas preenchidas com as categorias STRIDE, pilar CIA e impacto comercial do Clube Aurora.
- [ ] **Caso 3 (F3 - Injeção de SQL):** Lacunas preenchidas correlacionando a f-string com o risco de vazamento de dados de clientes VIP.
- [ ] **Caso 4 (F4 - Hardening de Contêiner):** Lacunas preenchidas explicando os riscos de usar `:latest` e contêiner rodando como `root` .
- [ ] **Parte 2 (Governança e RBAC):** Proposta de recusa técnica ao pedido do Tio Armando para conceder admin total à gerente Carla, aplicando o princípio de Menor Privilégio e Segregação de Funções (SoD).

- [ ] **Parte 3 (Observabilidade):** Listagem de eventos mínimos de auditoria que a aplicação deveria registrar em banco de dados.

Envio:

- [ ] Relatório `TEMPLATE_TG.md` salvo e submetido para avaliação da **professora**.

Nível 2 Misto

Você combina correções práticas em 3 falhas (**F1, F2, F4**) com análise conceitual de 4 falhas (**F3, F5, F6, F7**).

No Repositório (Código e Git):

- [ ] Fork do repositório original criado na sua conta do GitHub.
- [ ] GitHub Actions ativado na aba **Actions** do seu fork.
- [ ] **F1 Corrigido:** Arquivo `.gitignore` contém `.env`; arquivo `.env` foi desindexado do Git (`git rm --cached .env`); arquivo `.env.example` foi criado com valores de exemplo seguros.
- [ ] **F2 Corrigido:** Arquivo `requirements.txt` atualizado com versões seguras de Flask, Werkzeug, Gunicorn e Urllib3.
- [ ] **F4 Corrigido:** Arquivo `Dockerfile` endurecido com imagem base específica (`python:3.11-slim`), usuário não-root e instrução `HEALTHCHECK`.
- [ ] Commits realizados com mensagens claras no padrão Conventional Commits.
- [ ] Pull Request aberto da sua branch de desenvolvimento para a branch `main` do seu fork.

No Relatório (`aluno/TEMPLATE_TM.md`):

- [ ] O relatório `aluno/TEMPLATE_TM.md` (ou via Word em `docs/docx/TEMPLATE_TM.docx`) foi preenchido.
- [ ] **Guia de Apoio:** Consultou o `GUIA_NIVEL_2_MISTO.md` para orientações sobre as correções de F1, F2, F4 e modelagem de ameaças.
- [ ] Tabela de modelagem de ameaças (STRIDE e Tríade CIA) preenchida para F3, F5, F6 e F7 (utilizando o exemplo resolvido de F3 do guia como referência).
- [ ] Parecer técnico de Governança e RBAC sobre a solicitação do Tio Armando e Carla.
- [ ] Planejamento de eventos de auditoria e observabilidade contra ataques.
- [ ] Prints ou links dos steps de Hadolint e Trivy FS passando com status verde no GitHub Actions.

Envio:

- [ ] Link do repositório/fork e link do Pull Request informados no relatório.
- [ ] Relatório `TEMPLATE_TM.md` devidamente submetido para avaliação da **professora**.

[START] Nível 3 Técnica

Você atua como Engenheiro(a) DevSecOps responsável por zerar todas as 7 vulnerabilidades e garantir os gates 100% verdes.

No Repositório (Código e Pipeline):

- [ ] **Guia de Apoio:** Consultou o `GUIA_NIVEL_3_TECNICO.md` e o `PLANO_DE_TESTES_DEBUGGING.md` para depurar e validar localmente as 7 correções.

- [ ] Fork criado e GitHub Actions ativo.
- [ ] **F1:** Higiene de segredos completa (`.gitignore` , `.env.example` , `.env` desindexado).
- [ ] **F2:** `requirements.txt` com versões seguras sem CVEs (`Total: 0` no Trivy FS).
- [ ] **F3:** Consulta SQL em `app/db.py` convertida para consulta parametrizada com `?` (`0 findings` no Semgrep).
- [ ] **F4:** `Dockerfile` endurecido com multi-stage build, usuário `nonroot` , `apt-get upgrade` e `HEALTHCHECK` (`DL3007` resolvido e `Total: 0` no Trivy Image).
- [ ] **F5:** Cabeçalhos de segurança HTTP injetados na aplicação (`Content-Security-Policy` , `X-Frame-Options` , `X-Content-Type-Options` , `Strict-Transport-Security`).
- [ ] **F6:** Privilégio mínimo garantido em `app/db.py` (`role="client"`) e trava de autorização `@auth.require_role("admin")` em `app/main.py` .
- [ ] **F7:** `docker-compose.yml` saneado sem `privileged: true` , sem `/var/run/docker.sock` montado e com portas seguras.
- [ ] **Testes de Aplicação:** Os testes unitários executam com sucesso (`pytest -v` verde).
- [ ] **Validador:** O script `python professor/validate.py .` (ou `.ps1`) valida 7/7 falhas corrigidas.

No GitHub Actions:

- [ ] Job `pipeline-estatica` 100% verde (Hadolint, Trivy FS, Semgrep).
- [ ] Job `pipeline-dinamica` 100% verde (Trivy Image zerado, aplicação rodando e ZAP Baseline com zero erros críticos).
- [ ] Pull Request aberto para a branch `main` do seu fork contendo o histórico atômico dos seus commits.

No Relatório (`aluno/TEMPLATE_EVIDENCIAS.md`):

- [ ] O relatório `aluno/TEMPLATE_EVIDENCIAS.md` (ou via Word em `docs/docx/TEMPLATE_EVIDENCIAS.docx`) foi preenchido.
- [ ] Links do repositório e do Pull Request preenchidos.
- [ ] Prints comprovando o pipeline antes (vermelho) e depois (verde).
- [ ] Tabela comparativa de cada uma das 7 correções preenchida.
- [ ] (Opcional/Bônus): Registro formal de exceção de risco em `.trivyignore` , geração de SBOM ou branch protection rules documentados.

Envio:

- [ ] Relatório `TEMPLATE_EVIDENCIAS.md` e links ativos do fork/PR submetidos para avaliação da **professora**.